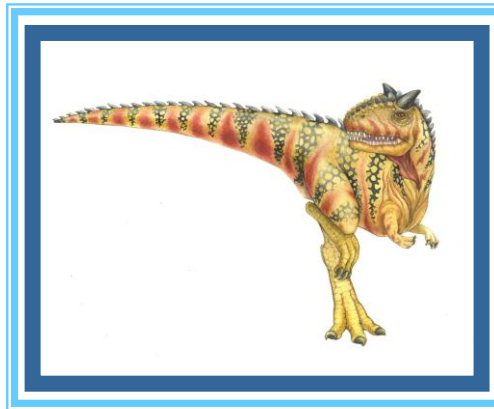
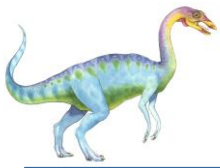


Protection and Security

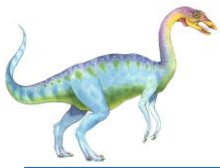




Protection and Security

- The Security Problem
- Program Threats
- System and Network Threats
- Cryptography as a Security Tool
- User Authentication
- Implementing Security Defenses
- Firewalling to Protect Systems and Networks
- Computer-Security Classifications
- An Example: Windows 7

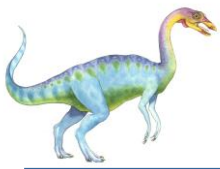




Objectives

- To discuss security threats and attacks
- To explain the fundamentals of encryption, authentication, and hashing
- To examine the uses of cryptography in computing
- To describe the various countermeasures to security attacks





Concepts

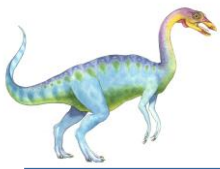
■ *Protection:*

- ▶ Mechanisms and policy to keep programs and users from accessing or changing stuff they should not do
- ▶ *Internal* to OS

■ *Security:*

- ▶ Issues *external* to OS
- ▶ Authentication of user, validation of messages, malicious or accidental introduction of flaws, etc.



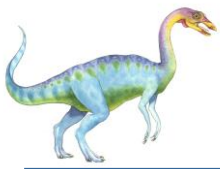


Protection

Control access by limiting file types accessed by different users

Only authorized processes can operate on memory segments, CPU and other resources





Security

- Protect information integrity by ensuring authentication of system users
- Prevent unauthorized access
- Prevent malicious destruction of data
- Prevent accidental introduction of inconsistency





What Security Goals Does Operating System Provide?

- Originally: time-sharing computers: enabling multiple users to securely share a computer
 - Separation and sharing of processes, memory, files, devices, etc.
- What is the threat model?
 - Users may be malicious, users have terminal access to computers, software may be malicious/buggy, and so on
- Security mechanisms
 - Memory protection
 - Processor modes
 - User authentication
 - File access control

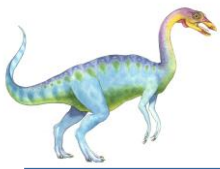




What Security Goals Does Operating System Provide?

- More recent past and present: Networked desktop computers: ensure secure operation in networked environment
- New threat?
 - Attackers coming from the network. Network-facing programs on computers may be buggy. Users may be hurt via online communication.
- Security mechanisms
 - Authentication; Access Control
 - Secure Communication (using cryptography)
 - Logging & Auditing
 - Intrusion Prevention and Detection
 - Recovery

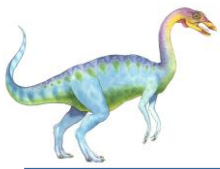




The Security Problem

- System **secure** if resources used and accessed as intended under all circumstances
 - Unachievable
- **Intruders** (**crackers**) attempt to breach security
- **Threat** is potential security violation
- **Attack** is attempt to breach security
- Attack can be accidental or malicious
- Easier to protect against accidental than malicious misuse

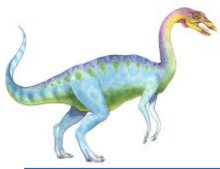




Security Violation Categories

- **Breach of confidentiality**
 - Unauthorized reading of data
- **Breach of integrity**
 - Unauthorized modification of data
- **Breach of availability**
 - Unauthorized destruction of data
- **Theft of service**
 - Unauthorized use of resources
- **Denial of service (DOS)**
 - Prevention of legitimate use

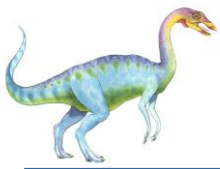




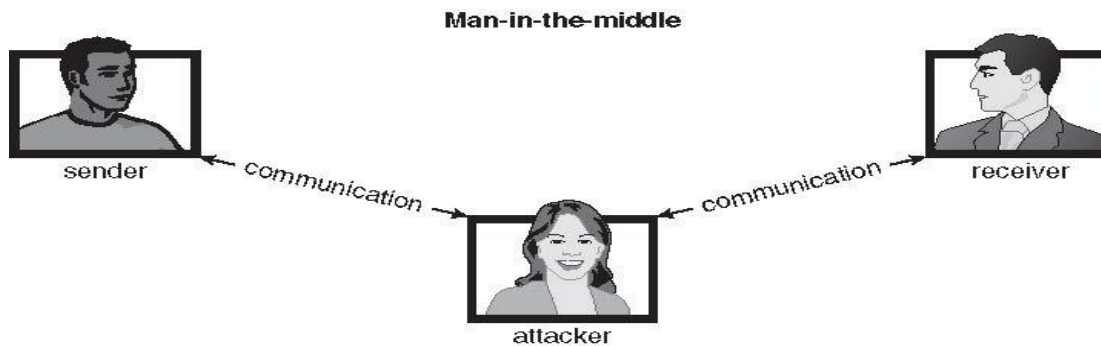
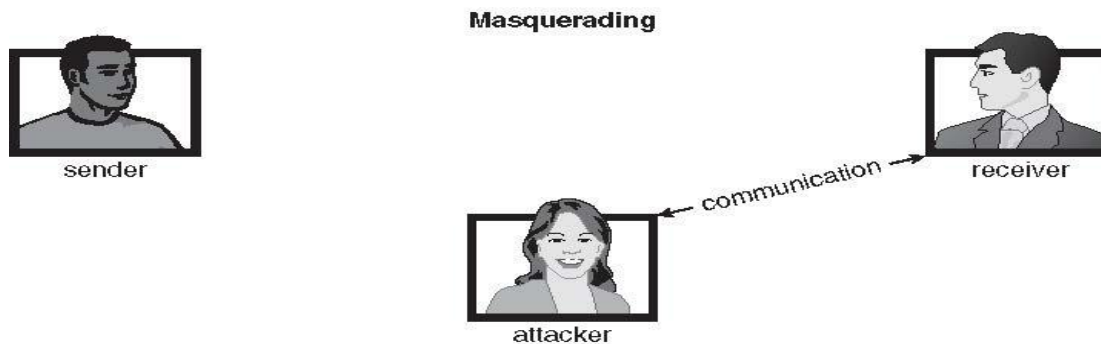
Security Violation Methods

- **Masquerading** (breach **authentication**)
 - Pretending to be an authorized user to escalate privileges
- **Replay attack**
 - As is or with **message modification**
- **Man-in-the-middle attack**
 - Intruder sits in data flow, masquerading as sender to receiver and vice versa
- **Session hijacking**
 - Intercept an already-established session to bypass authentication





Standard Security Attacks

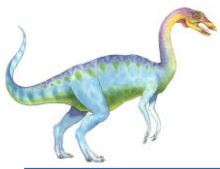




Security Measure Levels

- Impossible to have absolute security, but make cost to perpetrator sufficiently high to deter most intruders
- Security must occur at four levels to be effective:
 - **Physical**
 - ▶ Data centers, servers, connected terminals
 - **Human**
 - ▶ Avoid **social engineering**, **phishing**, **dumpster diving**
 - **Operating System**
 - ▶ Protection mechanisms, debugging
 - **Network**
 - ▶ Intercepted communications, interruption, DOS
- Security is as weak as the weakest link in the chain
- But can too much security be a problem?





Attacks from Inside the System

- An insider is a person who has logged into a computer using legitimate username and password. In a system with long and special symbol based passwords, breaking them to login may be difficult. However, weak passwords may be broken easily and the intruder can cause damages to the user information or steal them.
- A person who has logged in can also exploit the system vulnerabilities (bugs or loop holes) to gain entry into other users' area including administrators and work in the system with their privileges. These attackers are also called crackers, as they break the password system to gain unauthorized entries into other users' area. Attacks by insiders include:
 - Trojan Horses ■ Login Spoofing
 - Logic Bombs ■ Trap Doors ■ Buffer Overflow

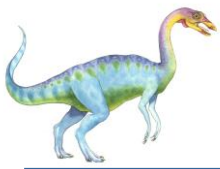




Program Threats

- Many variations, many names
- **Trojan Horse**
 - Code segment that misuses its environment
 - Exploits mechanisms for allowing programs written by users to be executed by other users
 - **Spyware, pop-up browser windows, covert channels**
 - Up to 80% of spam delivered by spyware-infected systems
- **Trap Door**
 - Specific user identifier or password that circumvents normal security procedures
 - a security hole, inserted at programming time in the system for later use
 - Could be included in a compiler
 - How to detect them?





Program Threats (Cont.)

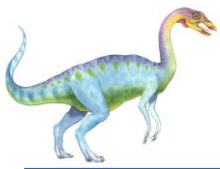
■ Logic Bomb

- Program that initiates a security incident under certain circumstances.
- The internal code of any software that will set of a malicious function when specified conditions are met

■ Stack and Buffer Overflow

- Exploits a bug in a program (overflow either the stack or memory buffers)
- Failure to check bounds on inputs, arguments
- Write past arguments on the stack into the return address on stack
- When routine returns from call, returns to hacked address
 - ▶ Pointed to code loaded onto stack that executes malicious code
- Unauthorized user or privilege escalation



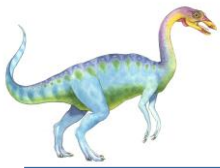


Program Threats (Cont.)

■ Viruses

- The pattern that can be used to identify a virus is known as virus signature
- Code fragment embedded in legitimate program
- Self-replicating, designed to infect other computers
- Very specific to CPU architecture, operating system, applications
- Usually borne via email or as a macro
- Visual Basic Macro to reformat hard drive

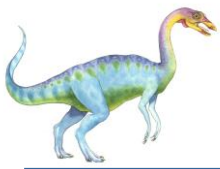




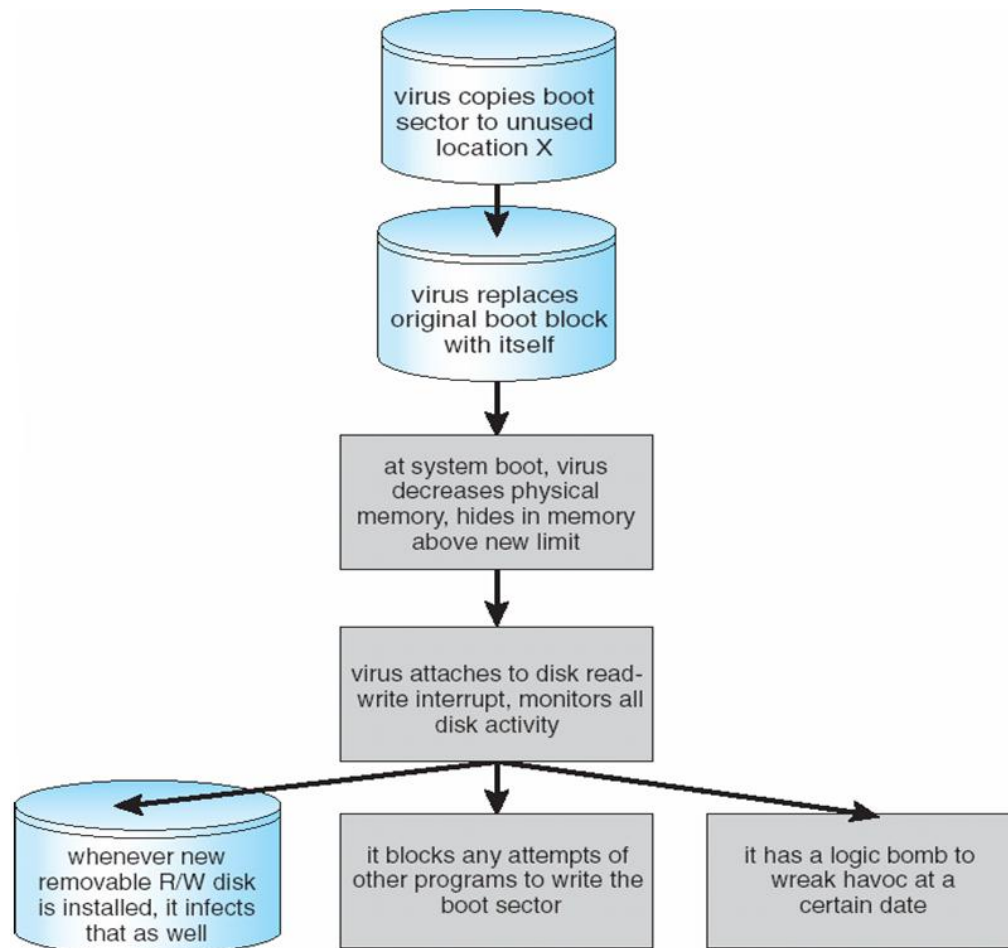
Program Threats (Cont.)

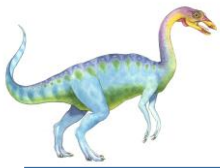
- **Virus dropper** inserts virus onto the system
- Many categories of viruses, literally many thousands of viruses
- File Virus attaches itself to the executable file.
- Multipartite viruses attack on files, boot sector and memory.





A Boot-sector Computer Virus

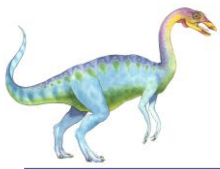




System and Network Threats

- Some systems “open” rather than **secure by default**
 - Reduce **attack surface**
 - But harder to use, more knowledge needed to administer
- Network threats harder to detect, prevent
 - Protection systems weaker
 - Ex: port scanning search for vulnerabilities to attack
 - More difficult to have a shared secret on which to base access
 - No physical limits once system attached to internet
 - ▶ Or on network with system attached to internet
 - Even determining location of connecting system difficult
 - ▶ IP address is only knowledge

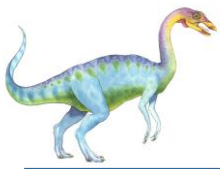




System and Network Threats (Cont.)

- **Worms** – use **spawn** mechanism; standalone program
- **Port scanning**
 - Automated attempt to connect to a range of ports on one or a range of IP addresses
 - Detection of answering service protocol
 - Detection of OS and version running on system
 - `nmap` scans all ports in a given IP range for a response
 - `nessus` has a database of protocols and bugs (and exploits) to apply against a system



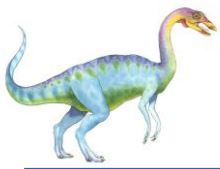


System and Network Threats (Cont.)

■ Denial of Service

- Overload the targeted computer preventing it from doing any useful work
- **Distributed denial-of-service (DDOS)** come from multiple sites at once
- Consider the start of the IP-connection handshake (SYN)
 - ▶ How many started-connections can the OS handle?
- Consider traffic to a web site
 - ▶ How can you tell the difference between being a target and being really popular?

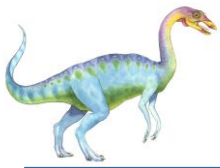




Cryptography as a Security Tool

- Broadest security tool available
 - Internal to a given computer, source and destination of messages can be known and protected
 - ▶ OS creates, manages, protects process IDs, communication ports
 - Source and destination of messages on network cannot be trusted without cryptography
 - ▶ Local network – IP address?
 - Consider unauthorized host added
 - ▶ WAN / Internet – how to establish authenticity
 - Not via IP address

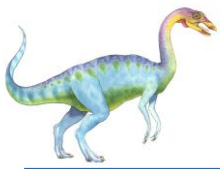




Cryptography

- Means to constrain potential senders (*sources*) and / or receivers (*destinations*) of *messages*
 - Based on secrets (**keys**)
 - Enables
 - ▶ Confirmation of source
 - ▶ Receipt only by certain destination
 - ▶ Trust relationship between sender and receiver





Encryption

- Constrains the set of possible receivers of a message
- **Encryption** algorithm consists of
 - Set K of keys
 - Set M of Messages
 - Set C of ciphertexts (encrypted messages)
 - A function $E : K \rightarrow (M \rightarrow C)$. That is, for each $k \in K$, E_k is a function for generating ciphertexts from messages
 - ▶ Both E and E_k for any k should be efficiently computable functions
 - A function $D : K \rightarrow (C \rightarrow M)$. That is, for each $k \in K$, D_k is a function for generating messages from ciphertexts
 - ▶ Both D and D_k for any k should be efficiently computable functions





Encryption (Cont.)

- An encryption algorithm must provide this essential property:
Given a ciphertext $c \in C$, a computer can compute m such that $E_k(m) = c$ only if it possesses k
 - Thus, a computer holding k can decrypt ciphertexts to the plaintexts used to produce them, but a computer not holding k cannot decrypt ciphertexts
 - Since ciphertexts are generally exposed (for example, sent on the network), it is important that it be infeasible to derive k from the ciphertexts

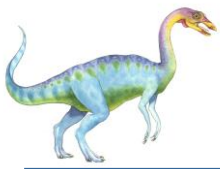




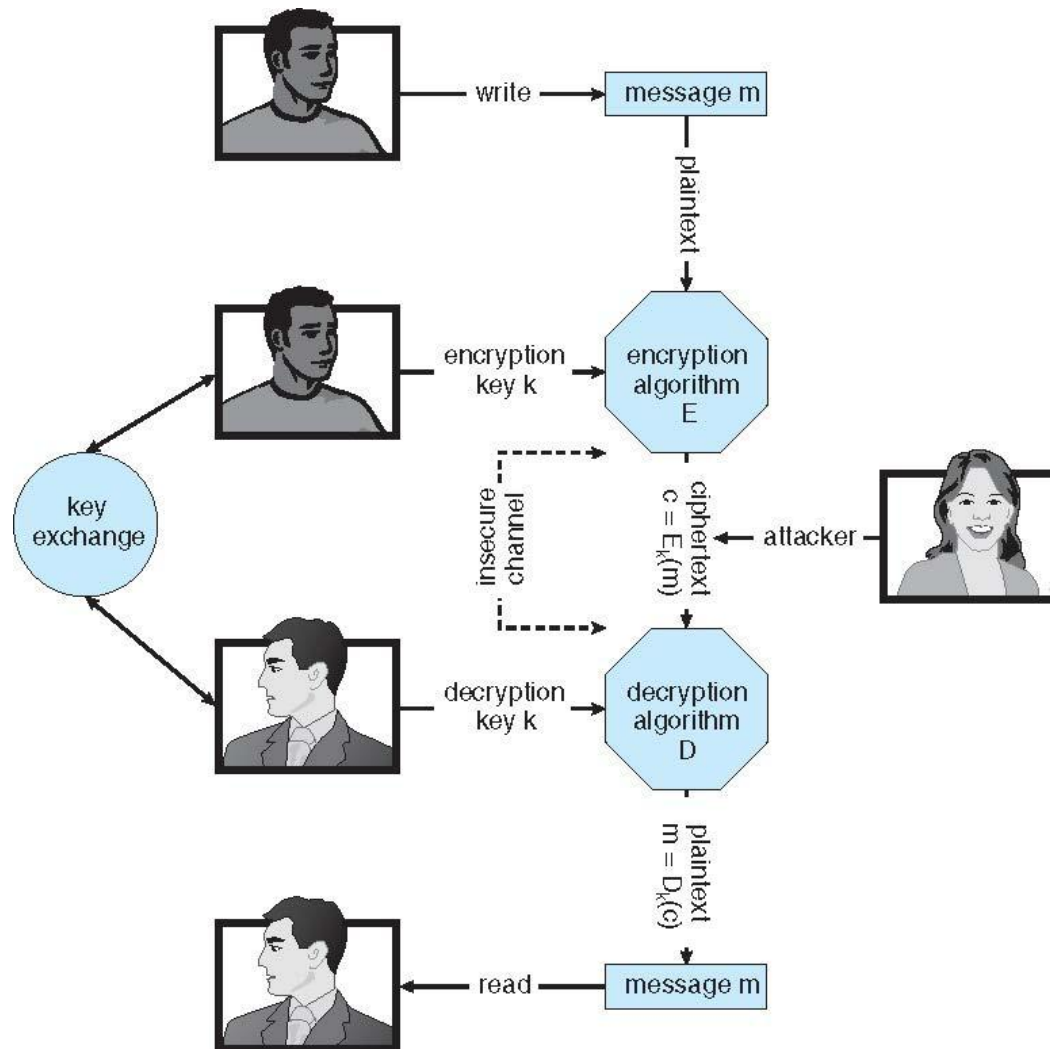
Symmetric Encryption

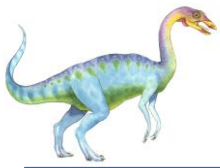
- Same key used to encrypt and decrypt
 - Therefore k must be kept secret
- DES was most commonly used symmetric block-encryption algorithm (created by US Govt)
 - Encrypts a block of data at a time
 - Keys too short so now considered insecure
- Triple-DES considered more secure
 - Algorithm used 3 times using 2 or 3 keys
 - For example $c = E_{k3}(D_{k2}(E_{k1}(m)))$
- 2001 NIST adopted new block cipher - Advanced Encryption Standard (**AES**)
 - Keys of 128, 192, or 256 bits, works on 128 bit blocks
- RC4 is most common symmetric stream cipher, but known to have vulnerabilities
 - Encrypts/decrypts a stream of bytes (i.e., wireless transmission)
 - Key is a input to pseudo-random-bit generator
 - ▶ Generates an infinite **keystream**





Secure Communication over Insecure Medium





Asymmetric Encryption

- **Public-key encryption** based on each user having two keys:
 - **public key** – published key used to encrypt data
 - **private key** – key known only to individual user used to decrypt data
- Must be an encryption scheme that can be made public without making it easy to figure out the decryption scheme
 - Most common is **RSA** block cipher
 - Efficient algorithm for testing whether or not a number is prime
 - No efficient algorithm is known for finding the prime factors of a number

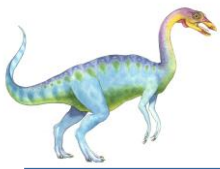




Authentication

- Constraining set of potential senders of a message
 - Complementary to encryption
 - Also can prove message unmodified
- Algorithm components
 - A set K of keys
 - A set M of messages
 - A set A of authenticators
 - A function $S : K \rightarrow (M \rightarrow A)$
 - ▶ That is, for each $k \in K$, S_k is a function for generating authenticators from messages
 - ▶ Both S and S_k for any k should be efficiently computable functions
 - A function $V : K \rightarrow (M \times A \rightarrow \{\text{true}, \text{false}\})$. That is, for each $k \in K$, V_k is a function for verifying authenticators on messages
 - ▶ Both V and V_k for any k should be efficiently computable functions

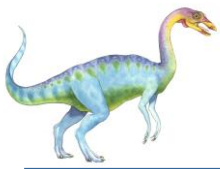




Authentication (Cont.)

- For a message m , a computer can generate an authenticator $a \in A$ such that $V_k(m, a) = \text{true}$ only if it possesses k
- Thus, computer holding k can generate authenticators on messages so that any other computer possessing k can verify them
- Computer not holding k cannot generate authenticators on messages that can be verified using V_k
- Since authenticators are generally exposed (for example, they are sent on the network with the messages themselves), it must not be feasible to derive k from the authenticators
- Practically, if $V_k(m, a) = \text{true}$ then we know m has not been modified and that send of message has k
 - If we share k with only one entity, know where the message originated

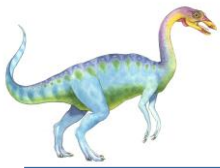




Authentication – Hash Functions

- Basis of authentication
- Creates small, fixed-size block of data **message digest** (**hash value**) from m
- Hash Function H must be collision resistant on m
 - Must be infeasible to find an $m' \neq m$ such that $H(m) = H(m')$
- If $H(m) = H(m')$, then $m = m'$
 - The message has not been modified
- Common message-digest functions include **MD5**, which produces a 128-bit hash, and **SHA-1**, which outputs a 160-bit hash
- Not useful as authenticators
 - For example $H(m)$ can be sent with a message
 - ▶ But if H is known someone could modify m to m' and recompute $H(m')$ and modification not detected
 - ▶ So must authenticate $H(m)$

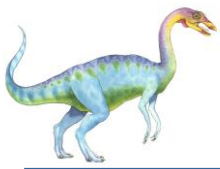




Authentication - MAC

- Symmetric encryption used in **message-authentication code (MAC)** authentication algorithm
- Cryptographic checksum generated from message using secret key
 - Can securely authenticate short values
- If used to authenticate $H(m)$ for an H that is collision resistant, then obtain a way to securely authenticate long message by hashing them first
- Note that k is needed to compute both S_k and V_k , so anyone able to compute one can compute the other

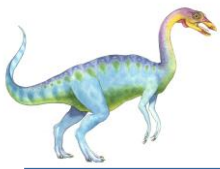




Authentication (Cont.)

- Why authentication is a subset of encryption?
 - Fewer computations (except for RSA digital signatures)
 - Authenticator usually shorter than message
 - Sometimes want authentication but not confidentiality
 - ▶ Signed patches et al
 - Can be basis for **non-repudiation**





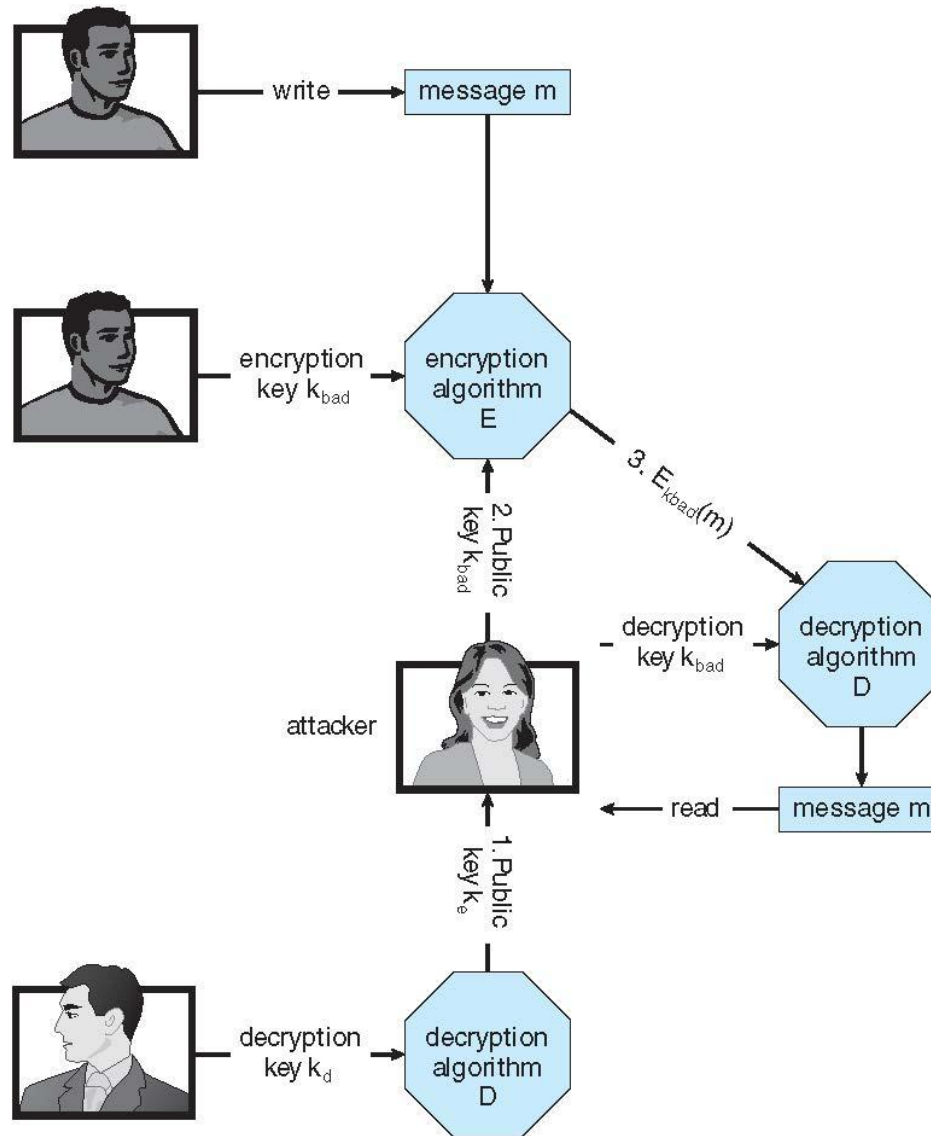
Key Distribution

- Delivery of symmetric key is huge challenge
 - Sometimes done **out-of-band**
- Asymmetric keys can proliferate – stored on **key ring**
 - Even asymmetric key distribution needs care – man-in-the-middle attack





Man-in-the-middle Attack on Asymmetric Cryptography





Implementation of Cryptography

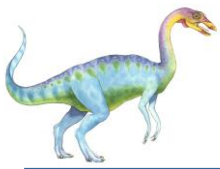
- Can be done at various **layers** of ISO Reference Model
 - SSL at the Transport layer
 - Network layer is typically **IPSec**
 - ▶ **IKE** for key exchange
 - ▶ Basis of **Virtual Private Networks (VPNs)**
- Why not just at lowest level?
 - Sometimes need more knowledge than available at low levels
 - ▶ i.e. User authentication
 - ▶ i.e. e-mail delivery

OSI model	
7. Application Layer	
NNTP · SIP · SSI · DNS · FTP · Gopher · HTTP · NFS · NTP · SMPP · SMTP · SNMP · Telnet · Netconf · (more)	
6. Presentation Layer	
MIME · XDR · TLS · SSL	
5. Session Layer	
Named Pipes · NetBIOS · SAP · L2TP · PPTP · SPDY	
4. Transport Layer	
TCP · UDP · SCTP · DCCP · SPX	
3. Network Layer	
IP (IPv4, IPv6) · ICMP · IPsec · IGMP · IPX · AppleTalk	
2. Data Link Layer	
ATM · SDLC · HDLC · ARP · CSLIP · SLIP · GFP · PLIP · IEEE 802.3 · Frame Relay · ITU-T G.hn DLL · PPP · X.25 · Network Switch · DHCP	
1. Physical Layer	
EIA/TIA-232 · EIA/TIA-449 · ITU-T V-Series · I.430 · I.431 · POTS · PDH · SONET/SDH · PON · OTN · DSL · IEEE 802.3 · IEEE 802.11 · IEEE 802.15 · IEEE 802.16 · IEEE 1394 · ITU-T G.hn PHY · USB · Bluetooth · Hubs	
This box: view · talk · edit	

OSI Model			
	Data unit	Layer	Function
Host layers	Data	7. Application	Network process to application
		6. Presentation	Data representation, encryption and decryption, convert machine dependent data to machine independent data
		5. Session	Interhost communication
	Segments	4. Transport	End-to-end connections and reliability, flow control
Media layers	Packet/Datagram	3. Network	Path determination and logical addressing
	Frame	2. Data Link	Physical addressing
	Bit	1. Physical	Media, signal and binary transmission

Source:
http://en.wikipedia.org/wiki/OSI_model

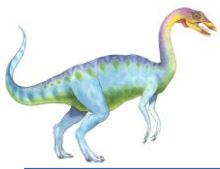




Encryption Example - SSL

- Insertion of cryptography at one layer of the ISO network model (the transport layer)
- SSL – Secure Socket Layer (also called TLS)
- Cryptographic protocol that limits two computers to only exchange messages with each other
 - Very complicated, with many variations
- Used between web servers and browsers for secure communication (credit card numbers)
- The server is verified with a **certificate** assuring client is talking to correct server
- Asymmetric cryptography used to establish a secure **session key** (symmetric encryption) for bulk of communication during session
- Communication between each computer then uses symmetric key cryptography
- More details in textbook





User Authentication

- Crucial to identify user correctly, as protection systems depend on user ID
- User identity most often established through **passwords**, can be considered a special case of either keys or capabilities
- Passwords must be kept secret
 - Frequent change of passwords
 - History to avoid repeats
 - Use of “non-guessable” passwords
 - Log all invalid access attempts (but not the passwords themselves)
 - Unauthorized transfer
- Passwords may also either be encrypted or allowed to be used only once
 - Does encrypting passwords solve the exposure problem?
 - ▶ Might solve **sniffing**
 - ▶ Consider **shoulder surfing**
 - ▶ Consider Trojan horse keystroke logger
 - ▶ How are passwords stored at authenticating site?





Passwords

- Encrypt to avoid having to keep secret
 - But keep secret anyway (i.e. Unix uses superuser-only readable file `/etc/shadow`)
 - Use algorithm easy to compute but difficult to invert
 - Only encrypted password stored, never decrypted
 - Add “salt” to avoid the same password being encrypted to the same value
- One-time passwords
 - Use a function based on a seed to compute a password, both user and computer
 - Hardware device / calculator / key fob to generate the password
 - ▶ Changes very frequently
- Biometrics
 - Some physical attribute (fingerprint, hand scan)
- Multi-factor authentication
 - Need two or more factors for authentication
 - ▶ i.e. USB “dongle”, biometric measure, and password

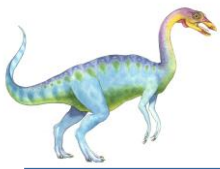




Implementing Security Defenses

- **Defense in depth** is most common security theory – multiple layers of security
- **Security policy** describes what is being secured
- Vulnerability assessment compares real state of system / network compared to security policy
- Intrusion detection endeavors to detect attempted or successful intrusions
 - **Signature-based** detection spots known bad patterns
 - **Anomaly detection** spots differences from normal behavior
 - ▶ Can detect **zero-day** attacks
 - **False-positives** and **false-negatives** a problem
- Virus protection
 - Searching all programs or programs at execution for known virus patterns
 - Or run in **sandbox** so can't damage system
- Auditing, accounting, and logging of all or specific system or network activities
- Practice **safe computing** – avoid sources of infection, download from only “good” sites, etc

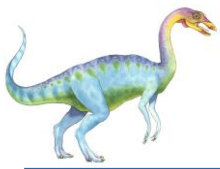




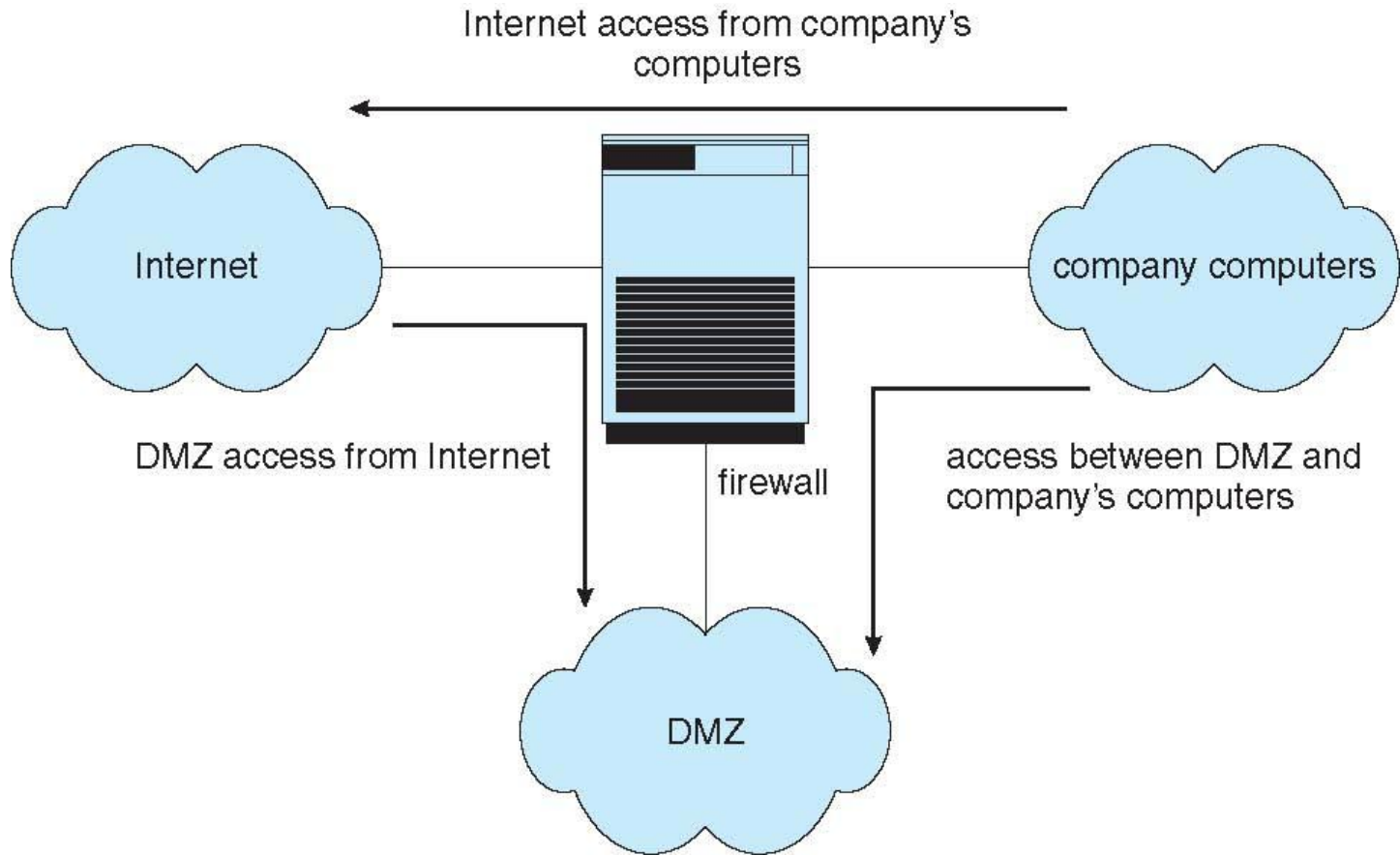
Firewalling to Protect Systems and Networks

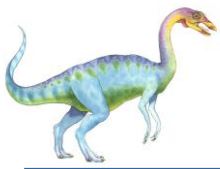
- A network **firewall** is placed between trusted and untrusted hosts
 - The firewall limits network access between these two **security domains**
- Can be tunneled or spoofed
 - Tunneling allows disallowed protocol to travel within allowed protocol (i.e., telnet inside of HTTP)
 - Firewall rules typically based on host name or IP address which can be spoofed
- **Personal firewall** is software layer on given host
 - Can monitor / limit traffic to and from the host
- **Application proxy firewall** understands application protocol and can control them (i.e., SMTP)
- **System-call firewall** monitors all important system calls and apply rules to them (i.e., this program can execute that system call)





Network Security Through Domain Separation Via Firewall

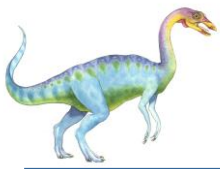




Example: Windows 7

- Security is based on **user accounts**
 - Each user has unique security ID
 - Login to ID creates **security access token**
 - ▶ Includes security ID for user, for user's groups, and special privileges
 - ▶ Every process gets copy of token
 - ▶ System checks token to determine if access allowed or denied
- Uses a **subject** model to ensure access security
 - A subject tracks and manages permissions for each program that a user runs
- Each object in Windows has a security attribute defined by a security descriptor
 - For example, a file has a security descriptor that indicates the access permissions for all users

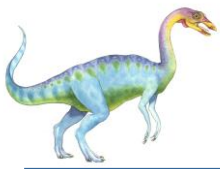




Example: Windows 7 (Cont.)

- Win added mandatory integrity controls – assigns **integrity label** to each securable object and subject
 - Subject must have access requested in discretionary access-control list to gain access to object
- Security attributes described by security descriptor
 - Owner ID, group security ID, discretionary access-control list, system access-control list

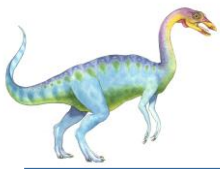




Goals of Protection

- Operating system consists of a collection of *objects* (hardware or software)
- Each object has a unique *name* and can be accessed through a well-defined set of *operations*.
- *Protection problem* – to ensure that each object is accessed correctly and only by those processes that are allowed to do so.



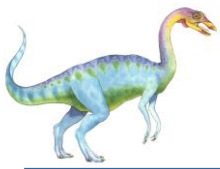


Guiding Principles of Protection

- *Principle of least privilege*
 - Programs, users and systems should be given just enough privileges to perform their tasks

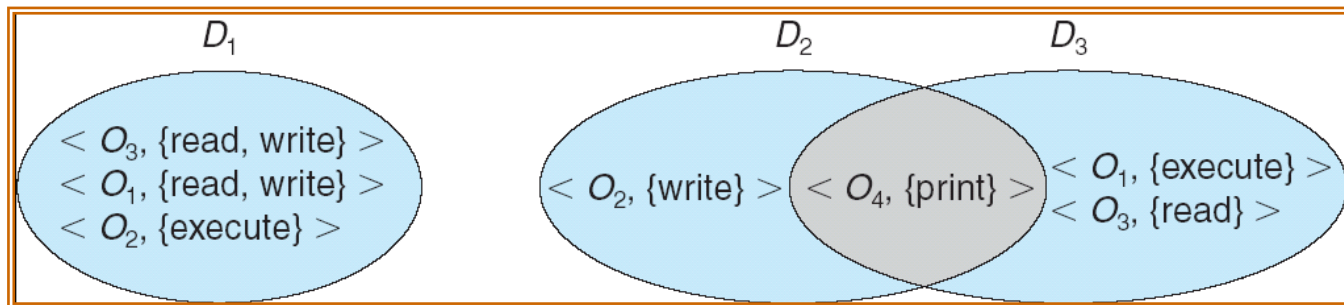
- Separate *policy* from *mechanism*
 - *Mechanism*: the stuff built into the OS to make protection work
 - *Policy*: the data that says who can do what to whom





Domain Structure

- Access-right = $\langle \text{object-name}, \text{rights-set} \rangle$
where *rights-set* is a subset of all valid operations that can be performed on the object.
- Domain = set of access-rights





Conceptual Representation – Access Matrix

- View protection as a matrix (*access matrix*)
- Rows represent domains
- Columns represent objects
- $Access(i, j)$ is set of operations that process executing in $Domain_i$ can invoke on $Object_j$





domain \ object	object			
	F_1	F_2	F_3	printer
D_1	read		read	
D_2				print
D_3		read	execute	
D_4	read write		read write	

- Columns are *access control lists (ACLs)*

- ▶ Associated with each object

- Rows are *capabilities*

- ▶ Associated with each user, group, or domain



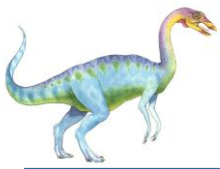


Unix & Linux

- System comprises many domains:—
 - Each user
 - Each group
 - Kernel/System

- (Windows has even more domains than this!)





Unix/Linux Matrix

	<i>file1</i>	<i>file 2</i>	<i>file 3</i>	<i>device</i>	<i>domain</i>
<i>User/Domain 1</i>	<i>r</i>	<i>rx</i>	<i>rwX</i>	—	<i>enter</i>
<i>User/Domain 2</i>	<i>r</i>	<i>X</i>	<i>rx</i>	<i>rwX</i>	—
<i>User/Domain 3</i>	<i>rw</i>	—	—	—	—
...					

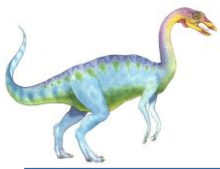
- Columns are *access control lists* (ACLs)

- ▶ Associated with each object

- Rows are *capabilities*

- ▶ Associated with each user or each domain





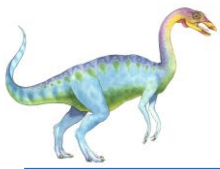
Notes

Back doors are sometimes created by vendors for solving problems. A back door is a planned opening in a security apparatus used to bypass system security. A buffer overflow is a type of denial-of-service attack that allows a hacker to create a backdoor. A front door attack is one in which the hacker uses a password and user ID for illegitimate entry into a system. A Trojan horse is a program used to obtain or destroy information in a system. an unintentional back door can be created by Running redundant services or Upgrading your system.

Ways in which protection may be provided for system users and groups include assigning the lowest level of access for each user or group that allows them to perform their jobs. In addition, you should carefully examine any default accounts and remove, reset, or rename them as appropriate. Segmenting the operating system and using auditing methods will protect the various files and services on the system, but not specifically system users and groups.

By partitioning the physical disk on a program by program basis and restricting a service or daemon's access to only a specific partition, you can provide protection for your operating system's files.

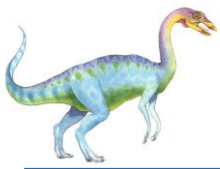




Notes

- The use of proper security techniques can minimize the threat of attackers and prevent all but the most determined and skilled hackers from accessing your system. No system is 100 percent secure, but a secure system will allow appropriate access for authorized users.
- Virtual memory is a common security feature found in modern operating systems. It allows the operating system to use a portion of the hard drive as if it were RAM, which can help protect against buffer overflow attacks and other security threats. Device drivers, system registry, and task scheduler are also important components of operating systems, but they are not specific to security features.
- When planning a security policy for your company, you should classify your systems, assign risk factors, determine security priorities for each system, define acceptable and unacceptable activities and access, and decide how you will educate all your employees about security. Publicly exposed servers require Level I security.





Notes

- Network permissions should be established so that users can accomplish their tasks, but cannot access any system resources that are not necessary so that only the resources authorized for that user will be at risk. Permissions will not affect a hacker's ability to steal a legitimate user's identity
- Operating Systems generally identifies/authenticates users using following three ways : Username / Password, User card/key and User attribute.
- Trojan Horse : Such program traps user login credentials and stores them to send to malicious user who can later on login to computer and can access system resources.



End of Chapter 15

